

Project

1 Introduction

In this assignment, students are required to develop a project in a team. This project aims to develop students' skills in developing applications following the Secure Software Development Life Cycle (SSDLC) process.

The main goal is to get a computational system secure. Such computational system must have a well-defined purpose (school management system, social network, sales management and so on) with necessary functionalities to fulfill it.

The assignment is to be made in groups of four/five students of the same PL class (exceptions must be approved). The topic/theme or purpose is free (however, it must be discussed with PL instructors) and must be communicated until week 5 by email to `pbs@isep.ipp.pt`. This communication must include the name of the system, a brief description, the number and name of all member as well as the class id (according). The accepted proposals will be added to a list in the Section 7.

2 Requirements (some)

The project consist on a development of a back-end application (running in a web server). The back-end application is a web application programming interface (API) (REST API or something similar) plus a relational database (memory database is not allowed).

Mandatory features:

- Considering the Domain-Driven Design (DDD) concepts, the Domain model has to encompass at least three aggregates (one of them could be for users).
- Authorization (with at least three different roles).
- Execution of the operating system functionalities in back-end server, such as creating directories, reading/writing files and so on.

3 Contents and Delivery

The project is split into two phases: Phase 1 and Phase 2. During the Phase 1, which takes three weeks, it is required to perform (and document) operations related to SSDLC Analysis and Design steps.

- Phase 1
 - Analysis/Requirements
 - * Functional and non-functional requirements

- * Secure development requirements
- * Abuse cases
- * ...
- Design
 - * Threat modeling
 - * Secure design
 - * Secure architecture
 - * Security test planning
 - * ...

Phase 2 is split into two sprints, each taking three weeks, and it is required to perform (and document) operations related to SSDLC Implementation, Testing and Deployment steps.

- Phase 2: Sprint 1
 - Development and Testing;
 - * DevSecOps: pipeline
 - * Code reviews
 - * SAST, DAST and IAST
 - * SCA
 - * Security testing
 - * ...
- Phase 2: Sprint 2
 - Development, Testing and Deployment;
 - * DevSecOps: pipeline
 - * Code reviews
 - * SAST/DAST and IAST
 - * SCA
 - * Security testing
 - * Security configuration and installation
 - * Security assessment
 - * ...

The project code and documentation have to be available at one **git-based web repository** for instructors. Teams must give **administrator** permission to their PL instructor. To do so, they must use one of the following email addresses (check with your PL class instructor):

- crr@isep.ipp.pt
- ffs@isep.ipp.pt
- nap@isep.ipp.pt
- pbs@isep.ipp.pt

The development of the project must be supported by a repository, in which the teams must automate the SSDLC operations to aid their work.

- The repository name has to have the following structure: `desofs2026_<class-id>_<team-number>` (for example: `desofs2026_thu_crr_1`). Check the `<class-id>` field in Section 7.
- In the repository, at root level, there must have a folder called `Deliverables`.
 - This folder is to be used for storing *deliverables* and the ASVS checklist of each project phase or sprint.
 - * A *deliverable* is a summary (with repository references for documentation, code snippets, files, and others) of the work carried out in a phase or sprint.
 - * The OWASP Application Security Verification Standard (ASVS) is a list of security related elements that can be used as the main guideline for developing secure software and also to specify the security level.
 - These *deliverables* and ASVS checklist will be used for phase or sprint assessments.

4 Planning

The next table shows the week semester mapping, in which it is considered the first week day is on **Monday** and the last week day is on **Sunday**.

Week	Dates	Week	Dates
1	23/02 – 01/03/2026	9	27/04 – 03/05/2026
2	02/03 – 08/03/2026		Queima
3	09/03 – 15/03/2026	10	11/05 – 17/05/2026
4	16/03 – 22/03/2026	11	18/05 – 24/05/2026
5	23/03 – 29/03/2026	12	25/05 – 31/05/2026
6	30/03 – 05/04/2026	13	01/06 – 07/06/2026
	Easter	14	08/06 – 14/06/2026
7	13/04 – 19/04/2026	15	15/06 – 21/06/2026
8	20/04 – 26/04/2026	16	22/06 – 28/06/2026

The following table shows the milestones. The **Start** refers to **Monday** at **0:01** and **End** to **Sunday** at **23:59** of the respective week (there are two exceptions). **Launch** and **Assessment** refer to whole week.

Week nr	Milestone
1	
2	
3	Launch: Project
4	
5	End: Teamwork composition
6	Project: Phase 1
Easter	
7	Project: Phase 1
8	Submission: Project: Phase 1 (20/04) Assessment: Project: Phase 1 Project: Phase 2: Sprint 1
9	Assessment: Project: Phase 1
Queima	

10	Project: Phase 2: Sprint 1
11	Submission: Project: Phase 2: Sprint 1 (18/05) Assessment: Project: Phase 2: Sprint 1 Start: Project: Phase 2: Sprint 2
12	Assessment: Project: Phase 2: Sprint 1
13	
14	
15	Submission: Project: Phase 2: Sprint 2 (16/06) Assessment: Project: Phase 2

Pay attention: * These assessments will take place in the PL classes and all team members have to be (mandatory) present.

5 Assessment

The DESOFS course has defined two assessment **Moments** plus **Exam**:

- Moment 1 (M1): Project: phase 1;
- Moment 2 (M2): Project: phase 2;
- Exam (E).

These Moments (M1 and M2) and E are:

- **"Mandatory" for all students, regardless of their status.**
- M1, M2, and E are graded in the interval [0.00,20.00];

The DESOFS final grade (CF) is determined as follows:

- $CF = M1 * 0.20 + M2 * 0.40 + E * 0.40$.
 - All CF components are graded in the interval [0.00,20.00]
 - $M2 = 0.15 * \text{Sprint1} + 0.15 * \text{Sprint2} + 0.10 \text{ Project}$.
 - * Sprint1 = Project: Phase 2: Sprint 1
 - * Sprint2 = Project: Phase 2: Sprint 2
 - * Project = Overall Project

To grant access to the E:

- $(M1 * 0.20 + M2 * 0.40) / 0.60 \geq 8.00$ (8.00/20.00).

To get success, you have to:

- Grant access to the E
- $E \geq 8.00$ (8.00/20.00).
- $CF \geq 9.50$

M1 and M2 are carried out in teams of 4/5 students, however the evaluation can be individual.

6 Detailed Rubrics

The project will be assessed using the following rubric. The table describes the criteria for the maximum score (100%). We will assign scores of 100%, 75%, 50%, 25% and 0 according to the fulfillment of these criteria.

6.1 Phase 1: Threat Modeling

Criteria	Weight	Excellent:100%
Organization and Language	5%	Good organization of document and repository. Easy to follow, with all components linked to a main document. No major language (Grammar, Usage, Mechanics, Spelling) errors.
Analysis	10%	System overview, architecture, and complete, well documented, domain model; all major components described;
Dataflow	15%	Relevant data flows are documented in sufficient detail; System components, data flows, trust boundaries, and external entities are documented and use correct notation. Level 0 and 1 DFDs presented and levels 2+ presented when complexity justifies
Threat Identification and Analysis	20%	Identifies most relevant threats, properly applying STRIDE per element of the DFD. Details attack vectors and threat agents with abuse cases.
Risk Assessment	10%	Employ a well-defined risk assessment methodology to prioritise risks; justifies decisions
Mitigations	10%	Proposes specific, clear and feasible mitigations to threats identified, focusing on high priority ones
Requirements	20%	Security requirements justified (best practice, from threats identified, regulatory, ...) . Addressing: authentication & access control, data security, communication, input validationand data handling, third-party components, logging and monitoring.
Security Testing	10%	Defines security testing methodology; Defines or refers to abuse cases; Threat modelling review process; Completeness of ASVS assessment, focusing on architecture; Traceability between documented security requirements and tests

6.2 Phase 2: Sprint 1

Criteria	Weight	Excellent:100%
Organization and Language	5%	Good organization of document and repository. Easy to follow, with all components linked to a main document. No major language (Grammar, Usage, Mechanics, Spelling) errors.
Development	30%	Developed enough functionality to showcase automation. Documented set of development best practices adopted. Evidence of security audits, code reviews, static code analysis, software composition analysis, and other relevant practices.
Build and Test	30%	Inventory of components, execution of test plans, dynamic analysis, configuration validation, artifact scanning, and other relevant practices.
Pipeline automation	20%	Most practices are automated.
ASVS	15%	Completeness of ASVS assessment; Traceability between documented security requirements and tests

6.3 Phase 2: Sprint 2

Criteria	Weight	Excellent:100%
Organization and Language	5%	Good organization of document and repository. Easy to follow, with all components linked to a main document. No major language (Grammar, Usage, Mechanics, Spelling) errors.
Development	35%	Developed functionality according to complexity requirements (number of aggregates, authorization, backend functionality). Well organized code, according to best practices: domain encapsulation, consistent security controls, and more. Logging mechanisms introduced.
Build and Test	35%	Scripted builds and tests. Mostly fully automated. Complete set of tests from static analysis, component analysis, dynamic analysis and more.
Production	5%	Appreciated, but not the emphasis of this project. Evidence of management of production infrastructure, logging and traceability, incident management, patch management, configuration management, OR other relevant practices.
Operate	5%	Appreciated, but not the emphasis of this project. Evidence of system and user monitoring, backup and restore, penetration testing, vulnerability management OR other relevant practices.

ASVS	15%	Completeness of ASVS assessment; Traceability between documented security requirements and tests
------	-----	--

6.4 Project

Criteria	Weight	Excellent:100%
Overall quality	100%	Overall high quality in delivered code, report and other artifacts. Very complete package. Practices from Phase I are very complete, or significantly improved.

7 Themes/Topics and Teams

7.1 Class-ID: tue_crr (Week day: Tuesday, Prof: CRR, Room: B309)

Team Number	Repo name	Team elements	Topic
1	desofs2026_tue_crr_1	• Name, number	App name

7.2 Class-ID: wed_ffs (Week day: Wednesday, Prof: FFS, Room: B407)

Team Number	Repo name	Team elements	Topic
1	desofs2026_wed_ffs_1	• Name, number	App name

7.3 Class-ID: wed_nap (Week day: Wednesday, Prof: NAP, Room: B306)

Team Number	Repo name	Team elements	Topic
1	desofs2026_wed_nap_1	• Name, number	App name

7.4 Class-ID: wed_pbs (Week day: Wednesday, Prof: PBS, Room: B309)

Team Number	Repo name	Team elements	Topic
1	desofs2026_wed_pbs_1	• Name, number	App name

7.5 Class-ID: thu_crr () Week day: Thursday, Prof: CRR, Room: B408)

Team Num- ber	Repo name	Team elements	Topic
1	desofs2026_t hu_crr_1	• Name, number	App name

7.6 Class-ID: thu_ffs (Week day: Thursday, Prof: FFS, Room: B409)

Team Number	Repo name	Team elements	Topic
1	desofs2026_t hu_ffs_1	• Name, number	App name